# Level-4 Gate Builder Checklist

For anyone building an AI agent that can read, call tools, or change systems. Use it in a design review or before you give an agent a new permission.

**The three-line gate.** Name the job. Name the stop rule. Name who signs. If you cannot fill all three, the agent is not ready to act.

**The Level-4 gate (my working label, not a standard).** Machine checks that fail closed. A human who signs off. An audit trail. Miss one and it is not a gate.

## Scope and permissions (excessive agency)

☐ The agent has a written allowlist of tools and actions. Anything else is denied by default.

☐ Credentials are scoped to the job: read when it only needs read, one API instead of admin.

☐ High-risk actions (money, access changes, deletes, production changes, outbound messages) are not callable with the agent's own credentials at all.

☐ There is a named owner and a kill switch.

## G1 Use: data privacy

☐ Every field is labeled public, internal, or sensitive. Not sure means sensitive.

☐ Sensitive values are masked before any non-approved or cloud model sees them.

☐ The outbound payload is scanned before the call (egress check), not just the input.

## G2 Prompt: guardrails and injection

☐ Text from tickets, documents, web pages, email, and tool output is data. It never grants authority.

☐ The never-allowed list is enforced in code, not only stated in the system prompt.

☐ The gate checks the proposed action and its source, not just the wording of the request.

## G3 Context: least data, every claim traced

☐ Retrieval runs with the role's permissions. Out-of-role documents are denied and the denial is logged.

☐ Every factual claim carries a source, and a check opens the source and compares. No source, no sentence.

## G4 Self-check and exit: fail closed

☐ Stop rules are specific and testable by code (for example: sources disagree, amount above PO, privileged group, outside sender).

☐ On a stop, the agent discards its draft, writes nothing, and asks a named person one specific question.

☐ Exceptions, timeouts, and unknown states return deny.

☐ The approver is a different identity from the agent, has context and time, and can say no without breaking anything.

## Audit trail

☐ Every allow, block, hand-back, and human decision is logged: what, when, which data, which rule, which person.

☐ The agent cannot write to or delete its own log. Store it append-only where the agent cannot reach.

☐ You could reconstruct any action during an incident review from the log alone.

## Test before it acts

☐ Synthetic data only, including curveballs: a hidden instruction in a document, two sources that disagree, a missing field, an over-permissioned request, and a gate that throws an error.

☐ Approval volume is low enough that a person actually reads each one (no rubber stamp).

References: OWASP Top 10 for LLM Applications 2025, LLM01 Prompt Injection and LLM06 Excessive Agency (genai.owasp.org).